UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

Seguridad y Auditoría de Sistemas

MANUAL DE ESCENARIOS Y VERIFICACIÓN NORMATIVA

Clínica Médica Vida Segura

Documento para el equipo auditor · Laboratorio VMware con Windows Server 2022

Campo	Valor
Curso	Seguridad y Auditoría de Sistemas
Institución	Universidad Mariano Gálvez de Guatemala
Autores	Edgar Javier Nij Manchame, Byron Geovanni Chicoj Perez, Christian Aldair Rosales
Versión	1.0, octubre de 2026
Marco normativo	ISO/IEC 27001:2022, ISO/IEC 27002:2022, ISO 27799:2016, NIST SP 800-53 Rev. 5, NIST SP 800-63B-4, CIS Benchmark Windows Server 2022

Índice general

Índice general 1
1. Alcance y carácter del laboratorio 2
2. Marco normativo aplicado 3
2.1 Diagnóstico: ¿están bien aplicadas las normas? 3
3. Preparación para auditar 5
3.1 Acceso al laboratorio 5
3.2 Cuentas y separación de funciones (NIST 800-53 AC-6) 5
3.3 Estado inicial limpio 5
3.4 Cómo se registra la evidencia 6
4. Control de acceso a expedientes 7
4.1 Modelo 7
4.2 Escenarios 7
C1. Médico modifica un expediente 7
C2. Recepción intenta modificar un expediente 7
C3. Cambio de privilegios 7
5. Autenticación y bloqueo de cuentas 9
5.1 Modelo 9
5.2 Escenarios 9
A1. Inicio de sesión fallido 9
A2. Bloqueo por intentos repetidos 9
A3. Contraseña que no cumple la política 9
6. Protección de sesiones 11
6.1 Escenarios 11
S1. Bloqueo manual de estación 11
S2. Bloqueo por inactividad 11
7. Registro y monitoreo 12
7.1 Escenarios 12
L1. Actualización del dashboard 12
L2. Borrado del registro de seguridad 12
L3. Estación fuera de línea 12
8. Respaldo y recuperación 13
8.1 Escenarios 13
R1. Restauración de un expediente borrado 13
9. Verificación de la evidencia 14
9.1 Integridad de los registros (NIST 800-53 AU-9) 14
9.2 Matriz de trazabilidad 14
9.3 Indicadores 15
10. Limitaciones conocidas 16
11. Implementación de lo que falta 17
11.1 Ajuste de la política de contraseñas 17

1. Alcance y carácter del laboratorio

Este documento está dirigido a quien audita el proyecto. Explica contra qué normas se evalúa cada control, cómo provocar cada escenario de prueba, qué debe registrar el sistema y cómo comprobar la evidencia. Complementa al Manual operativo, que explica el uso diario de los controles.

El principio de diseño es: **Windows ejecuta el control, la norma define el criterio**. Todo lo que se prueba es real dentro del laboratorio; lo único simulado son los datos de pacientes.

Componente	Qué es real	Qué es simulado
Dominio y autenticación	Active Directory, Kerberos, políticas de contraseña y bloqueo	Nada
Control de acceso	Permisos NTFS y recurso compartido por grupos	Nada
Auditoría y monitoreo	Registro Security, SACL, script y dashboard HTML	Nada
Respaldo	Windows Server Backup sobre disco dedicado	Nada
Expedientes	Archivos y carpetas	El contenido: son expedientes de prueba sin datos reales
Infraestructura	VMs en VMware (SRV-CLINICA, PC-MEDICO, PC-RECEPCION)	El hardware físico de la clínica

2. Marco normativo aplicado

La columna **Estado** resume si la norma ya estaba aplicada en el proyecto antes de este documento: **Aplicada**, **Parcial** (se aplicaba pero sin evidencia o con valores por debajo del criterio) o **Nueva** (se incorpora con este documento).

Norma	Qué exige o aporta	Cómo se aplica en el laboratorio	Estado
ISO/IEC 27001:2022, Anexo A	Controles de seguridad de la información	Cada escenario indica su control; ver la matriz de la sección 9.2	Parcial → completa
ISO/IEC 27002:2022	Guía de implementación de los controles del Anexo A	Redacción de cada control y criterio de verificación	Aplicada
ISO 27799:2016	Gestión de seguridad de la información de salud con base en ISO 27002	Acceso por rol al expediente, auditoría de quién consulta información de pacientes, continuidad de los registros clínicos	Nueva
NIST SP 800-53 Rev. 5	Catálogo de controles: AC-2, AC-3, AC-6, AC-7, AC-11, AU-2, AU-6, AU-9, CP-9, CP-10	Cuentas, permisos, bloqueo por intentos, bloqueo de sesión, registro, revisión, protección de registros y respaldo	Parcial (AU-9 faltaba)
NIST SP 800-63B-4	Autenticación digital: longitud mínima, sin reglas de composición ni cambio periódico obligatorio, límite de intentos	Se compara la política del dominio con la norma y se documenta la desviación (sección 2.1)	Nueva
CIS Benchmark Windows Server 2022 (L1)	Valores recomendados de configuración segura	Se compara cada parámetro de contraseñas, bloqueo y sesión (sección 2.1)	Nueva
HIPAA Security Rule, 45 CFR 164.312 (referencia sectorial)	Control de acceso, cierre automático de sesión, controles de auditoría e integridad para información de salud	Referencia de buenas prácticas del sector salud; no es obligatoria en Guatemala	Referencia

2.1 Diagnóstico: ¿están bien aplicadas las normas?

Se comparó la configuración real del laboratorio (verificada con `net accounts /domain` y las GPO) con los valores que piden las normas:

Parámetro	Laboratorio	CIS L1	NIST 800-63B-4	Resultado
Longitud mínima	7	14 o más	15 (contraseña sola) u 8 (con MFA)	No cumple

Parámetro	Laboratorio	CIS L1	NIST 800-63B-4	Resultado
Historial	5	24 o más	No lo exige	No cumple CIS
Complejidad	Habilitada	Habilitada	No exigir reglas de composición	Cumple CIS; difiere de NIST
Vigencia máxima	42 días	365 o menos	No exigir cambio periódico	Cumple CIS; difiere de NIST
Umbral de bloqueo	5 intentos	5 o menos (no 0)	Limitar intentos fallidos	Cumple
Duración del bloqueo	2 min	15 min o más	—	No cumple
Bloqueo de pantalla	1 min	900 s o menos	—	Cumple
Protección de registros	Sin control	—	800-53 AU-9	No cumple
Separación de funciones	Solo administrador	—	800-53 AC-6	No cumple

Conclusión del diagnóstico

ISO/IEC 27001/27002 sí está bien aplicada: cada control tiene una implementación y una evidencia. Lo que faltaba era **citar el control y la norma en cada prueba** (como hace el ejemplo) y tres brechas técnicas: **valores de contraseña por debajo de CIS/NIST**, **registros sin protección de integridad (AU-9)** y **no hay un rol de auditor separado (AC-6)**.

Las secciones 3 y 8 explican cómo implementar lo que falta.

Desviación justificada de laboratorio

La duración de bloqueo de 2 minutos se mantiene en el laboratorio para poder repetir la demostración en clase sin esperar 15 minutos. En producción se aplicaría el valor de CIS (15 minutos). Documentar la desviación es parte de una buena auditoría.

3. Preparación para auditar

3.1 Acceso al laboratorio

Elemento	Valor
Servidor	SRV-CLINICA (192.168.10.10), Windows Server 2022, dominio CLINICA.local
Estaciones	PC-MEDICO (192.168.10.20) y PC-RECEPCION (192.168.10.30), Windows 10
Red	LAN_CLINICA 192.168.10.0/24 en VMware
Sitio del proyecto	https://enijm1.github.io/clinica-vida-segura/
Máquinas virtuales	Carpeta de Google Drive enlazada desde el sitio

3.2 Cuentas y separación de funciones (NIST 800-53 AC-6)

Quien ejecuta las pruebas no debe ser quien verifica la evidencia. Por eso se agrega una cuenta de auditor de solo lectura:

Rol	Cuenta	Para qué sirve en la auditoría
Operador	Administrador / Admin01	Ejecuta los escenarios y restablece el estado
Usuario médico	medico01	Escenarios de acceso permitido y bloqueo
Usuario recepción	recepcion01	Escenarios de acceso denegado y sesión
Auditor (nuevo)	aud-clinica	Lee el registro Security y el dashboard; no puede cambiar GPO, permisos ni usuarios

Implementación de la cuenta de auditor (en SRV-CLINICA, PowerShell como administrador):

```
New-ADUser -Name "aud-clinica" -SamAccountName aud-clinica -Path
"OU=Administracion,OU=Usuarios,OU=CLINICA,DC=clinica,DC=local" `
  -AccountPassword (Read-Host -AsSecureString "Contraseña") -Enabled $true
Add-ADGroupMember -Identity "Event Log Readers" -Members aud-clinica
# Lectura del dashboard
icacls "C:\MONITOREO_CLINICA" /grant "CLINICA\aud-clinica:(OI)(CI)R"
```

Comprobación: con aud-clinica, `Get-WinEvent -LogName Security -MaxEvents 5` debe funcionar; abrir la consola de directivas de grupo y editar una GPO debe dar **Acceso denegado**.

3.3 Estado inicial limpio

Verificación	Cómo
Cuentas desbloqueadas	`Search-ADAccount -LockedOut` no devuelve resultados; si hay, `Unlock-ADAccount medico01`
GPO aplicadas	`gpupdate /force` en cada estación y `gpresult /r`

Verificación	Cómo
Expedientes de prueba presentes	Expediente_Paciente_001 y 002 en \\SRV-CLINICA\Expedientes
Dashboard actualizado	La fecha de Última actualización tiene menos de 2 minutos
Estaciones encendidas	Sin aviso RPC en el dashboard

3.4 Cómo se registra la evidencia

Paso 1. Antes de cada escenario, el operador registra una **marca de prueba** en el servidor (comando abajo). Así se distingue una prueba de un incidente real (ISO 27001 8.15).

Paso 2. Ejecutar el escenario.

Paso 3. Revisar en el dashboard y en el Visor de eventos los eventos posteriores a la marca.

Paso 4. Al final de la sesión, la cuenta auditor exporta los registros y calcula su hash (sección 9.1).

```
# Una sola vez: crear el origen
New-EventLog -LogName Application -Source ClinicaPruebas
# Antes de cada escenario
Write-EventLog -LogName Application -Source ClinicaPruebas -EventId 9000 -EntryType
Information `
  -Message "INICIO escenario A2 - operador: $env:USERNAME"
# Al terminar
Write-EventLog -LogName Application -Source ClinicaPruebas -EventId 9001 -EntryType
Information `
  -Message "FIN escenario A2"
```

4. Control de acceso a expedientes

4.1 Modelo

Regla	Valor
Permisos por grupo	GG_MEDICOS: Modificar · GG_RECEPCION: Lectura y ejecución · Administradores: Control total
Recurso	C:\CLINICA_DATOS\Expedientes compartido como \\SRV-CLINICA\Expedientes
Auditoría (SACL)	GG_RECEPCION: errores · GG_MEDICOS: aciertos

4.2 Escenarios

C1. Médico modifica un expediente

Elemento	Detalle
Acción	Con medico01 en PC-MEDICO, abrir Expediente_Paciente_001 y guardar un cambio.
Se observa	El archivo se guarda sin error.
Eventos	4663 (acceso a objeto) con CLINICA\medico01 y la ruta del archivo.
Control y norma	5.15, 8.3, 8.15 · ISO 27799 · NIST AC-3, AU-2
Criterio	El evento identifica usuario, objeto y hora.

C2. Recepción intenta modificar un expediente

Elemento	Detalle
Acción	Con recepcion01 en PC-RECEPCION ejecutar `Add-Content` sobre Expediente_Paciente_002.
Se observa	PowerShell devuelve Acceso denegado; el archivo no cambia.
Eventos	Mensaje UnauthorizedAccessException; 4656 con resultado de error si la auditoría de errores está activa.
Control y norma	5.15, 8.3 · NIST AC-3, AC-6
Criterio	El contenido del archivo es idéntico antes y después (comprobar con `Get-FileHash`).

C3. Cambio de privilegios

Elemento	Detalle
Acción	Agregar un usuario de prueba a GG_MEDICOS y luego quitarlo.
Se observa	El usuario obtiene y pierde el acceso de escritura.
Eventos	4728 (miembro agregado) y 4729 (miembro quitado) con la cuenta que hizo el cambio.

Elemento	Detalle
Control y norma	5.18, 8.2 · NIST AC-2
Criterio	Ambos eventos aparecen y señalan al administrador que hizo el cambio.
Restablecer	Quitar el usuario de prueba del grupo.

5. Autenticación y bloqueo de cuentas

5.1 Modelo

Parámetro	Valor	Fuente
Umbral de bloqueo	5 intentos	Default Domain Policy · CIS 1.2
Duración del bloqueo	2 min (lab) / 15 min (producción)	CIS 1.2; desviación justificada
Longitud mínima	7 (actual) → 12 recomendado	CIS 1.1 · NIST 800-63B-4

5.2 Escenarios

A1. Inicio de sesión fallido

Elemento	Detalle
Acción	En PC-MEDICO escribir mal la contraseña de medico01 una vez.
Se observa	Windows indica contraseña incorrecta.
Eventos	4625 en la estación y 4771/4776 en SRV-CLINICA (fallo de validación de credenciales).
Control y norma	8.5, 8.15 · NIST AC-7
Criterio	El intento queda registrado con usuario, equipo y hora.

A2. Bloqueo por intentos repetidos

Elemento	Detalle
Acción	Repetir el intento fallido hasta superar el umbral.
Se observa	«La cuenta a que se hace referencia está bloqueada».
Eventos	4740 (cuenta bloqueada) en SRV-CLINICA; CUENTA BLOQUEADA en el dashboard.
Control y norma	8.5 · NIST AC-7 · CIS 1.2
Criterio	El bloqueo ocurre en el intento número 5, ni antes ni después.
Restablecer	Esperar la duración del bloqueo o `Unlock-ADAccount medico01`.

A3. Contraseña que no cumple la política

Elemento	Detalle
Acción	Intentar cambiar la contraseña de un usuario de prueba por una de 5 caracteres.
Se observa	Windows rechaza el cambio.
Eventos	Mensaje de que la contraseña no cumple los requisitos.
Control y norma	5.17 · NIST IA-5 · CIS 1.1
Criterio	Ninguna contraseña por debajo de la longitud mínima es aceptada.

6. Protección de sesiones

6.1 Escenarios

S1. Bloqueo manual de estación

Elemento	Detalle
Acción	Con medico01 pulsar Win + L y desbloquear.
Se observa	La pantalla pide contraseña.
Eventos	4800 (bloqueada) y 4801 (desbloqueada) en PC-MEDICO, visibles en el dashboard.
Control y norma	7.7, 8.1 · NIST AC-11 · HIPAA 164.312(a)(2)(iii)
Criterio	Ambos eventos con usuario y equipo correctos.

S2. Bloqueo por inactividad

Elemento	Detalle
Acción	Iniciar sesión con recepcion01, no tocar el equipo y cronometrar.
Se observa	A los 60 s la pantalla se bloquea.
Eventos	4800 en PC-RECEPCION.
Control y norma	7.7 · NIST AC-11 · CIS 900 s o menos
Criterio	Tiempo medido ≤ 60 s (diferencia entre la última acción y el 4800).

7. Registro y monitoreo

7.1 Escenarios

L1. Actualización del dashboard

Elemento	Detalle
Acción	Registrar una marca de prueba y esperar la tarea programada.
Se observa	La fecha de Última actualización cambia.
Eventos	Evento 9000 (ClinicaPruebas) y la nueva fila en el panel.
Control y norma	8.15, 8.16 · NIST AU-6
Criterio	El dashboard se actualiza en 2 minutos o menos.

L2. Borrado del registro de seguridad

Elemento	Detalle
Acción	En un snapshot de prueba de SRV-CLINICA, el operador limpia el registro Security desde el Visor de eventos.
Se observa	El registro queda casi vacío.
Eventos	1102 (se borró el registro de auditoría) con la cuenta que lo hizo.
Control y norma	8.15 · NIST AU-9
Criterio	El borrado deja rastro y aparece en el dashboard como REGISTRO BORRADO (requiere agregar el 1102 al script).
Restablecer	Revertir el snapshot de VMware.

L3. Estación fuera de línea

Elemento	Detalle
Acción	Apagar PC-MEDICO y esperar la siguiente ejecución del script.
Se observa	Aviso «El servidor RPC no está disponible».
Eventos	Aviso en la sección de consultas del dashboard.
Control y norma	8.16
Criterio	El panel distingue una estación apagada de la ausencia de eventos.

8. Respaldo y recuperación

8.1 Escenarios

R1. Restauración de un expediente borrado

Elemento	Detalle
Acción	Respaldar CLINICA_DATOS, borrar Expediente_Paciente_002 y restaurarlo desde Windows Server Backup.
Se observa	El archivo vuelve a su ubicación.
Eventos	Registro Microsoft-Windows-Backup (copia y recuperación completadas).
Control y norma	8.13 · NIST CP-9, CP-10 · ISO 27799
Criterio	El hash SHA-256 del archivo restaurado es igual al calculado antes de borrarlo.

```
Get-FileHash "C:\CLINICA_DATOS\Expedientes\Expediente_Paciente_002.txt.txt" -Algorithm SHA256
```

9. Verificación de la evidencia

9.1 Integridad de los registros (NIST 800-53 AU-9)

Para que la evidencia no se pueda alterar sin que se note, al final de cada sesión la cuenta auditor exporta los registros y guarda su huella SHA-256. Si alguien modifica el archivo exportado, el hash ya no coincide.

```
$f = Get-Date -Format yyyyMMdd_HHmm
New-Item -ItemType Directory -Force C:\EVIDENCIA | Out-Null
wevtutil epl Security "C:\EVIDENCIA\Security_$f.evtx"
Get-FileHash "C:\EVIDENCIA\Security_$f.evtx" -Algorithm SHA256 |
  Select-Object Hash, Path | Export-Csv C:\EVIDENCIA\hashes.csv -Append -
NoTypeInformation
# Verificar más tarde
Import-Csv C:\EVIDENCIA\hashes.csv | ForEach-Object {
  [pscustomobject]@{ Archivo=$_.Path; Integro=((Get-FileHash $_.Path).Hash -eq $_.Hash)
} }
```

Complementos recomendados:

- Aumentar el tamaño del registro Security a 200 MB para no perder eventos: `wevtutil sl Security /ms:209715200`.
- Agregar el evento **1102** (registro borrado) al script del dashboard.
- Copiar `hashes.csv` fuera del servidor (por ejemplo a la carpeta de Drive del proyecto).

9.2 Matriz de trazabilidad

Control ISO/IEC 27001:2022	Otras normas	Escenarios	Eventos
5.15 Control de acceso	ISO 27799; NIST AC-3	C1, C2	4663, 4656
5.17 Información de autenticación	NIST IA-5; CIS 1.1; 800-63B-4	A3	Rechazo de contraseña
5.18 Derechos de acceso	NIST AC-2	C3	4728, 4729
7.7 Pantalla limpia	NIST AC-11; HIPAA 164.312	S1, S2	4800, 4801
8.2 Acceso privilegiado	NIST AC-6	C3, sección 3.2	4728; cuenta aud-clinica
8.3 Restricción de acceso a la información	ISO 27799; NIST AC-3	C1, C2	4663, 4656
8.5 Autenticación segura	NIST AC-7; CIS 1.2	A1, A2	4625, 4771, 4776, 4740
8.13 Respaldo de la información	NIST CP-9, CP-10	R1	Microsoft-Windows-Backup
8.15 Registro	NIST AU-2, AU-9	L1, L2, sección 9.1	9000, 1102, hashes.csv

Control ISO/IEC 27001:2022	Otras normas	Escenarios	Eventos
8.16 Actividades de monitoreo	NIST AU-6	L1, L3	Dashboard

9.3 Indicadores

Indicador	Meta	Cómo se mide
Escenarios con evidencia	100 %	Escenarios con evento o captura / escenarios ejecutados
Bloqueo en el intento correcto	100 %	Escenario A2: bloqueo exactamente en el intento 5
Tiempo de bloqueo de pantalla	≤ 60 s	Escenario S2, diferencia de tiempo hasta el 4800
Actualización del dashboard	≤ 2 min	Escenario L1
Restauraciones íntegras	100 %	Escenario R1: hash igual antes y después
Integridad de registros exportados	100 %	Verificación de hashes.csv
Parámetros alineados con CIS	≥ 80 %	Tabla de la sección 2.1

10. Limitaciones conocidas

Limitación	Efecto en la auditoría
Los expedientes son archivos de prueba	Se verifica el control, no un sistema clínico real
Duración de bloqueo de 2 minutos	Desviación justificada frente a CIS para poder repetir la demostración
Longitud mínima de 7 caracteres	No cumple CIS ni NIST 800-63B-4 hasta aplicar el ajuste de la sección 11
Los registros viven en el mismo servidor	La protección AU-9 depende de exportar y guardar los hashes fuera del servidor
Sin firewall perimetral ni segmentación	Fuera del alcance del laboratorio; recomendado para producción
Versiones de evaluación de Windows	Vigencia limitada de las VM

11. Implementación de lo que falta

Resumen de los cambios para cerrar las brechas del diagnóstico, en orden recomendado:

N.º	Cambio	Cierra	Sección
1	Marca de prueba con ClinicaPruebas	ISO 8.15	3.4
2	Cuenta aud-clinica en Event Log Readers	NIST AC-6	3.2
3	Exportación de registros con hash SHA-256	NIST AU-9	9.1
4	Evento 1102 en el dashboard y registro de 200 MB	NIST AU-9	9.1
5	Ajuste de la política de contraseñas	CIS 1.1 / NIST 800-63B-4	11.1

11.1 Ajuste de la política de contraseñas

Valores propuestos: longitud mínima 12 (para el personal) y 14 o más para administradores con una PSO, historial de 24, bloqueo de 15 minutos en producción.

```
Set-ADDefaultDomainPasswordPolicy -Identity clinica.local `
  -MinPasswordLength 12 -PasswordHistoryCount 24 `
  -LockoutThreshold 5 -LockoutDuration 00:15:00 -LockoutObservationWindow 00:15:00
net accounts /domain
```

Antes de aplicar

Tomen un snapshot de SRV-CLINICA en VMware. Las contraseñas actuales de los usuarios de prueba (por ejemplo Medico432) tienen 9 caracteres: después del cambio seguirán funcionando, pero al cambiarlas tendrán que tener 12 o más. Para la demostración en clase pueden dejar la duración de bloqueo en 2 minutos y explicarla como desviación justificada.